PE文件病毒原理

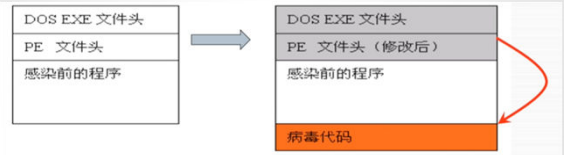
- PE(Portable Executable)文件
- Windows操作系统下使用的一种可执行文件，由COFF（UNIX平台下的通用对象文件格式）格式文件发展而来。
- 32位成为PE32，64位称为PE+或PE32+

PE文件种类

种类	主扩展名
可执行系列	EXE, SCR
库系列	DLL, OCX, CPL, DRV
驱动程序系列	SYS, VXD
对象文件系列	OBJ

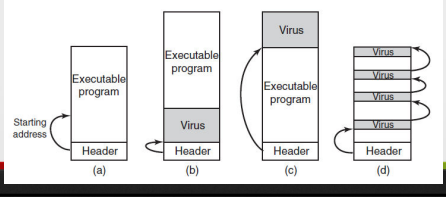
PE病毒感染的基本思路

- 何为文件感染？[或控制权获取]
  - 使目标PE文件具备[或启动]病毒功能[或目标程序]
  - 但不破坏目标PE文件原有功能和外在形态(如图标)等



感染PE文件的本质

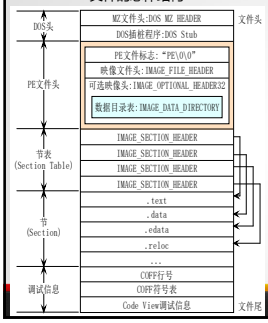
- 病毒插入宿主程序后，插入不同的位置，会造成PE文件头中有关参数需要被修改，如果修改的不正确，会造成宿主程序运行不正常，从而暴露病毒。

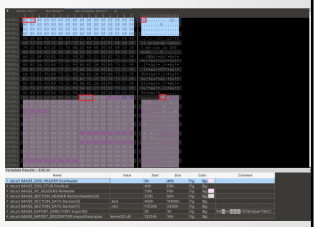


Win32病毒的运行过程

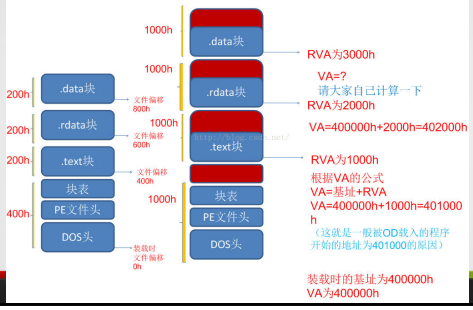
- 用户点击(或系统自动运行)HOST程序；
- 装载HOST程序到内存中；
- 通过PE文件中的AddressOfEntryPoint和ImageBase之和来定位第一条语句的位置；
- 从第一条语句开始执行(病毒代码可能在此时，也可能在HOST代码运行过程中获得控制权)；
- 病毒代码主题代码执行完毕，将控制权交还给HOST程序
- HOST程序继续执行

- PE文件的总体结构





PE磁盘文件与内存映像结构图

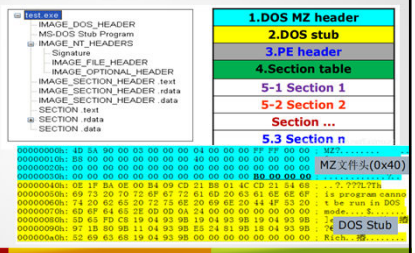


PE分析工具

看雪学院工具集

tool.pediy.com)

- 静态文件映像(静态分析)
  - PEView、Stud_PE
  - UltraEdit、010Editor
- 动态内存映像(动态分析)
  - Ollydbg、IDA、x64dbg
- 编辑工具：exeScope



可选映像头中的一些关键字段1

名字	描述
AddressOfEntryPoint *	PE装载器准备运行的PE文件的第一个指令的RVA。若要改变整个执行的流程，可以将该值指定到新的RVA，这样新RVA处的指令首先被执行。 ***(病毒感染中通用关键字段)***
ImageBase	PE文件的优先装载地址。比如，如果该值是400000h，PE装载器将尝试把文件装到虚拟地址空间的400000h处。若该地址区域已被其他模块占用，那PE装载器会选用其他空闲地址。
SectionAlignment	内存中节对齐的粒度。
FileAlignment	文件中节对齐的粒度。

可选映像头中的一些关键字段2

名字	描述
MajorSubsystemVersion **MinorSubsystemVersion**	win32子系统版本。若PE文件是专门为Win32设计的，该子系统版本必定是4.0否则对话框不会有3维立体感。
SizeOfImage	内存中整个PE映像体的尺寸。
SizeOfHeaders	所有头+节表的大小。可以以此值作为PE文件第一节的文件偏移量。
Subsystem	NT用来识别PE文件属于哪个子系统。
DataDirectory	一个**IMAGE_DATA_DIRECTORY** 结构数组。每个结构给出一个重要数据结构的RVA，比如引入地址表等。

编写PE文件病毒的关键技术

- **(1) 病毒的重定位**
- **(2)自获取API函数**
- **(3) 目标程序遍历搜索**
- **(4) 如何感染其它文件**
- **为什么重定位？病毒代码目标寄生位置不固定**
  - 本地DLL加载位置不固定；
  - 注入远程系统位置、环境不能确定

可选映像头的关键字段	
AddressOfEntry Point *	PE装载器准备运行的PE文件的第一个指令的RVA。(病毒感染的关键字段)
ImageBase	PE文件的优先装载地址

- 用ImageBase重定位不一定是真正的位置

- **(1) 重定位**

利用Call语句重定位

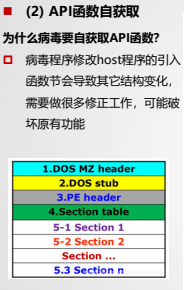
- 将下一条语句开始位置压入堆栈
- JMP到目标地址执行

```
        call delta      ;这条语句执行之后，堆栈顶端为 delta 在内存中的真正地址
delta:  pop ebp         ;这条语句将 delta 在内存中的真正地址存放在 ebp 寄存器中
        sub ebp,offset delta

        ......

        lea eax,[ebp+offset var1]
        ;这时 eax 中存放着 var1 在内存中的真实地址
```

- **(2) API函数自获取**

为什么病毒要自获取API函数?

- 病毒程序修改host程序的引入函数节会导致其它结构变化，需要做很多修正工作，可能破坏原有功能



(2) API函数自获取

- **关键点：使用API函数，但无引入函数节支撑**
- **① 如何获取API函数地址呢？**
  - DLL文件的引出函数节Kernel32.dll：
  - 核心API函数为 GetProcAddress和LoadLibraryA
  - GetProcAddress函数：包括两个参数，模块基地址和想要获取API函数名称，它将动态获得DLL函数的入口地址
  - LoadLibraryA函数：将制定的DLL动态链接库加载到内存中，返回值为DLL文件加载到内存中的基地址

(2) API函数自获取

- **② 当获得GetProcAddress和LoadLibraryA地址后，想获取任何一个API函数地址都可以。那么，怎么获取这两个函数的地址呢？**
  - 首先，获得kernel32.dll的模块加载基地址
    - ✓ 一种方法是采用硬编码（兼容性差），另一种方法通过Kernel模块中的相应结构和特征定位
  - 其次，通过Kernel32.dll的引出目录表结构定位具体函数的函数地址

(2) API函数自获取

- **③ 接着，看看获取Kernel32模块基地址的典型方法**
  - 定位Kernel32模块中任何一个地址，然后按照模块首地址特征（对齐于10000H，PE文件开始标识MZ）向低地址遍历定位PE文件头
  - Kernel32模块内的地址从何处获得？
  - 程序入口代码执行时Stack顶端存储的地址
    - – SEH链末端
    - – PEB相关数据结构指向了各模块地址
    - – Stack特定高端地址的数据

- **(3) 目标程序遍历搜索**
  - 通常以PE文件格式的文件（如EXE、SCR、DLL等）作为感染目标，其关键点为全盘查找或者部分盘符查找，遍历算法包括递归或非递归。
  - 通常调用两个API函数：FindFirstFile，FindNextFile

```
FindFile  Proc
    1.  指定找到的目录为当前工作目录
    2.  开始搜索文件(*.*)
    3.  该目录搜索完毕？是则返回，否则继续
    4.  找到文件还是目录？是目录则调用自身函数FindFile，否则继续
    5.  是文件，如符合感染条件，则调用感染模块，否则继续
    6.  搜索下一个文件(FindNextFile)，转到3继续
FindFile  Endp
```

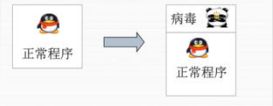
- **(4) 文件感染**

感染的关键是病毒代码能够得到运行，常用方法包括：

- **插入式感染**
  - 将病毒代码插入到HOST文件的代码节的中间或前后。
  - 这种感染方式会增加代码节的大小，并且可能修改HOST程序中的一些参数实际位置导致HOST程序运行失败。
- **伴随式感染**
  - 典型方法：备份HOST程序，用自身替换HOST程序
  - 当病毒执行完毕之后，再将控制权交给备份程序。

https://blog.csdn.net/Eastmount

- **捆绑释放型病毒**



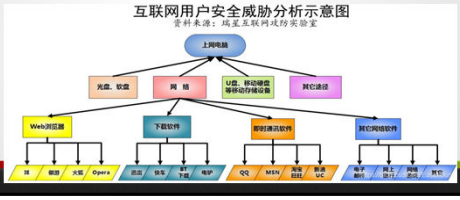
- 将目标HOST程序作为数据存储在病毒体内，当执行病毒程序时，它先执行病毒程序，然后还原并执行HOST文件，从而保证被感染的程序本身能正常运行，不会引起一些异样。
- 熊猫烧香病毒左边是一个正常程序（QQ），感染之后会将病毒放在前面，正常程序放在后面，程序运行之后，病毒会拿到控制权。但是程序图标会显示前面的病毒程序，显示熊猫烧香，这也是一个明显的被感染特征。
- 优点： 编写简单、效率高，可感染自校验程序
- 缺点： 被感染后的程序主体是病毒程序，易被发现（程序叠加+释放执行），程序图标问题

系统感染型病毒

- 本身不对PE文件做任何感染操作，但它感染的目标是操作系统，也是一种寄生类的方式，只是寄生目标有所不同。通常为独立个体，不感染系统内的其他文件
- 两个关键问题：
  - 如何再次获得控制权(自启动)？
  - 如何传播？

- **1.控制权再次获取（自启动）**
  - 操作系统启动流程：**BIOS --> 硬盘MBR --> 活动分区DBR --> 系统内部**
- 启动流程也是控制权传递的过程，操作系统本身跟启动方式相关的包括：
  - 注册表中的键值；系统中的特定位置；配置文件；特定路径的特定文件，如Explorer.exe（显示桌面）
  - 利用系统自动播放机制Autorun.inf
  - 在其他可执行文件嵌入少量触发代码
  - DLL劫持：替换已有DLL文件

- 如何传播？一切可对外交互的渠道都可传播，包括：
  - 各类存储设备（软盘、光盘、U盘、移动硬盘、智能设备）
  - 各类网络通信方式（QQ、MSN、Email、淘宝旺旺、微信、微博等）
  - 各类网络连接方式（有线、wifi、蓝牙等）
  - 各类网络应用（迅雷、BT等）

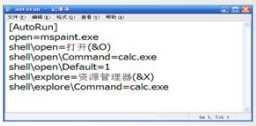


病毒的传播方式

翻转字符：邮件蠕虫中的邮件附件

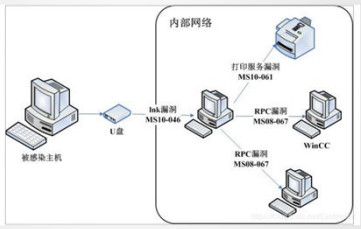
真实文件名：“5月TW行lmcod.scr”

通过可移动存储设备传播的非感染式病毒



伪装的文件夹

“摆渡”

“摆渡”的例子：

Stuxnet震网病毒